

Phase 15 Final Verification Report

Phase 15 Status

COMPLETE

Verification

TypeScript: 0 errors (npx tsc --noEmit passed clean)
Lint: 0 errors, 0 warnings (npm run lint passed clean)
Build: 0 errors (npm run build compiled clean to dist/)
Tests: 823 passed, 823 total across 111 test suites
Failures: 0 failed

Requirement Matrix

Requirement	Status	Implementation
Reports & Analytics	COMPLETE	Read-only MongoDB aggregation pipelines in <code>ReportRepository</code> and <code>ReportService</code> . Preserves integer minor units (<code>amountMinor</code>) and EGP currency semantics with no floating-point conversions.
Orders report	COMPLETE	Total count and breakdown grouped by <code>status</code> , with <code>dateFrom</code> , <code>dateTo</code> , and <code>status</code> query filters.
Revenue report	COMPLETE	Aggregates recognized operational revenue in minor units (<code>totals.totalMinor</code>), excluding cancelled/rejected orders by default, grouped by payment method and status.
Outside-Qena report	COMPLETE	Identifies orders outside Qena based on authoritative delivery address snapshot (<code>fulfillment.addressSnapshot.governorate</code> not in <code>['Qena', 'قنا']</code>).
Payment-method report	COMPLETE	Distribution by <code>paymentMethodKey</code> with exact order counts and monetary totals.
Service conversion	COMPLETE	Tracks service requests by status, total quotations, accepted/rejected quotations, and derives conversion rate (<code>acceptedQuotations / totalQuotations</code>).
Product/category demand	COMPLETE	Unwinds authoritative order items from <code>orders</code> collection, aggregating units sold and revenue by <code>productId</code> and <code>categorySnapshot</code> .
Pre-order demand	COMPLETE	Aggregates pre-order records from <code>preorders</code> collection, grouped by product and status.
Coupon usage	COMPLETE	Aggregates total redemptions and total discount minor units from <code>couponRedemptions</code> collection.
Audit logging	COMPLETE	Structured audit tracking across all critical mutations in orders, payments, inventory, shipping, quotations, returns, refunds, RBAC, settings, products, and coupons.
Audit immutability	COMPLETE	Append-only audit model with Mongoose pre-hooks actively rejecting any <code>update</code> or <code>delete</code> operations. No update or delete APIs exist.
Audit redaction	COMPLETE	Sensitive fields (passwords, hashes, tokens, secrets, raw/signed Cloudinary URLs, card details) sanitized at both write time and read time. Client IP auto-hashed via SHA-256.
Audit read API	COMPLETE	<code>GET /api/v1/admin/audit-logs</code> with safe pagination, whitelisted field filters (<code>entityType</code> , <code>action</code> , <code>actorId</code> , <code>dateFrom</code> , <code>dateTo</code>), and response redaction.
Report permission	COMPLETE	Protected by RBAC middleware requiring <code>reports.read</code> for reports and <code>audit.read</code> for audit logs. Store owner has universal wildcard bypass; customer access is rejected with <code>403 Forbidden</code> .

Files Created

- `src/database/migrations/scripts/20260928_013_audit_reports.migration.ts`
- `docs/PHASE-15-REPORTS-AUDIT.md`

- tests/unit/audit-redaction.test.ts
- tests/unit/audit-immutability.test.ts
- tests/unit/report-schemas.test.ts
- tests/unit/audit-reports-migration.test.ts
- tests/api/audit-admin-api.test.ts
- tests/api/report-admin-api.test.ts

Files Modified

- src/app.ts : Mounted adminAuditRouter under /api/v1/admin/audit-logs and adminReportRouter under /api/v1/admin/reports .
- src/config/openapi.ts : Documented GET /admin/audit-logs and GET /admin/reports/{report} endpoints, queries, and response envelopes.
- src/database/migrations/index.ts : Registered migration 20260928_013_audit_reports .
- src/modules/audit/types/audit.types.ts : Added reason , dedupeKey , session , targetType / targetId aliases, and filter types.
- src/modules/audit/models/audit-log.model.ts : Added reason , dedupeKey , immutability hooks, and query indexes.
- src/modules/audit/repositories/audit.repository.ts : Implemented paginated queries, dedupe lookup, and transactional write support.
- src/modules/audit/services/audit.service.ts : Implemented write-time and read-time deep redaction, IP hashing, deduplication check, and transaction participation.
- src/modules/audit/schemas/audit.schema.ts : Defined Zod query validation schema with injection prevention.
- src/modules/audit/controllers/audit.controller.ts : Implemented getAuditLogs with response formatting.
- src/modules/audit/routes/audit.routes.ts : Bound requireAuthentication() and requirePermission('audit.read') .
- src/modules/audit/index.ts : Exported all audit components.
- src/modules/reports/types/report.types.ts : Defined report types, filter interfaces, and response DTOs.
- src/modules/reports/schemas/report.schema.ts : Defined Zod parameter and query schemas with injection protection.
- src/modules/reports/repositories/report.repository.ts : Implemented aggregation pipelines for all 8 authoritative reports.
- src/modules/reports/services/report.service.ts : Implemented report dispatching and validation logic.
- src/modules/reports/controllers/report.controller.ts : Implemented getReport controller.
- src/modules/reports/routes/report.routes.ts : Bound requireAuthentication() and requirePermission('reports.read') .
- src/modules/reports/index.ts : Exported all report module components.
- src/modules/preorders/types/preorder.types.ts : Implemented preorder types.
- src/modules/preorders/models/preorder.model.ts : Implemented PreorderModel (collection 'preorders').
- src/modules/preorders/index.ts : Exported preorder model and types.
- src/modules/settings/types/setting.types.ts : Defined setting types.
- src/modules/settings/models/setting.model.ts : Defined SettingModel (collection 'settings').
- src/modules/settings/services/setting.service.ts : Added setting updates with settings.updated audit logging.
- src/modules/settings/index.ts : Exported settings module components.
- src/modules/users/services/roles.service.ts : Added updateRolePermissions with role.permissions_updated audit logging.

Database Changes

Collections

- auditLogs : Append-only collection for immutable audit history.

- `preorders` : Collection supporting upcoming student book and material pre-orders.

Indexes

- `auditLogs` :
 - `idx_audit_logs_entity_created` : { entityType: 1, entityId: 1, createdAt: -1 }
 - `idx_audit_logs_actor_created` : { actorId: 1, createdAt: -1 }
 - `idx_audit_logs_action_created` : { action: 1, createdAt: -1 }
 - `idx_audit_logs_created` : { createdAt: -1 }
 - `idx_audit_logs_dedupe` : { dedupeKey: 1 } (sparse, unique)
- `preorders` :
 - `idx_preorders_status_created` : { status: 1, createdAt: -1 }
 - { customerId: 1, createdAt: -1 }

Migrations

- `20260928_013_audit_reports` : Idempotent migration creating collections and indexes with non-destructive rollback.

API Changes

- `GET /api/v1/admin/reports/:report` : Generates authoritative operational aggregations (orders , revenue , outside-qena , payment-methods , service-conversion , product-demand , preorder-demand , coupon-usage). Protected by `reports.read` .
- `GET /api/v1/admin/audit-logs` : Retrieves paginated, filtered, redacted operational audit logs. Protected by `audit.read` .

Audit Integration

Audit logging is integrated across all required business modules:

1. **Orders:** `order.created` , `order.accepted` , `order.rejected` , `order.status_updated` , `order.cancelled` , `order.cod_confirmed` , `order.shipping_updated` .
2. **Payments:** `payment.proof_submitted` , `payment.confirmed` , `payment.rejected` , `payment.new_proof_requested` .
3. **Inventory:** `inventory.adjusted` , `inventory.stock_deducted` .
4. **Shipping:** `shipping.rule_created` , `shipping.rule_changed` , `shipping.rule_deactivated` .
5. **Quotations:** `quotation_sent` , `quotation_accepted` , `quotation_rejected` .
6. **Returns:** `return_approved_and_refund_initiated` , `return_rejected` .
7. **Refunds:** `refund_completed` , `refund_failed` .
8. **RBAC:** `role.permissions_updated` .
9. **Settings:** `settings.updated` .
10. **Products:** `product.create` , `product.update.price` , `product.update.availability` , `product.update.publication` .
11. **Coupons:** `coupon.created` , `coupon.updated` , `coupon.activated` , `coupon.deactivated` .

Redaction

The following sensitive data fields are deeply sanitized and redacted at ingestion and response boundaries:

- password , passwordHash
- token , accessToken , refreshToken , resetToken , guestAccessTokenHash
- cloudinaryApiSecret , cloudinarySignature
- Raw proof URLs, signed Cloudinary download URLs
- Credit card numbers, CVVs, and raw banking details
- Unnecessary PII and MongoDB connection strings
- Client IP addresses are converted to SHA-256 hashes

Tests

- **Unit Tests:**
 - tests/unit/audit-redaction.test.ts : Proves deep redaction and automatic IP hashing.
 - tests/unit/audit-immutability.test.ts : Proves model pre-hooks reject updates and deletes, deduplication on retries, and transactional rollback atomicity.
 - tests/unit/report-schemas.test.ts : Validates report identifiers, date ranges, limit caps, and operator injection rejection.
 - tests/unit/audit-reports-migration.test.ts : Validates migration up() , down() , and idempotency.
- **API Tests:**
 - tests/api/audit-admin-api.test.ts : Validates authentication (401), customer rejection (403), admin without audit.read rejection (403), owner / permitted admin success (200), pagination, filtering, and response redaction.
 - tests/api/report-admin-api.test.ts : Validates RBAC (reports.read), rejection of unsupported reports (400), injection rejection (400), and correctness across all 8 reports with seeded fixtures.
- **Regression Tests:**
 - Executed full suite across Phases 0–15: **823/823 tests passed across 111 test suites.**

Open Decisions

1. **KPI Targets:** Intentionally left uninvented per requirement.
2. **Audit Retention Policy:** Left unspecified per requirement; records are preserved append-only.
3. **Daily Aggregates:** Postponed until query volume warrants pre-aggregation.

Regression

All previous phases (0 through 14) continue to pass completely with 0 regressions.

Scope Boundary

Phase 15 is complete. No Phase 16, 17, or 18 implementation was performed.